ZERO TRUST NETWORK SEGMENTATION WITH EDR

Healthcare cybersecurity architecture & risk-management case study

Arley Alexandre | M.S. Cybersecurity & Information Assurance | Western Governors University

Project type: Graduate academic capstone; conceptual design and evaluation. Not a production deployment or independently measured field trial.

Executive overview

Developed a Zero Trust-inspired segmentation and endpoint detection and response (EDR) strategy for a modeled mid-sized healthcare provider. The design addresses ransomware propagation, excessive internal connectivity, limited endpoint visibility, and exposure of electronic protected health information (ePHI).

Scenario and business risk

The academic scenario describes approximately **100 Windows endpoints and 10 critical servers**, including electronic health record (EHR), file, and clinical systems. A relatively flat internal network allows broad east-west connectivity. A compromised workstation or vendor account could potentially reach sensitive resources, disrupt clinical services, or expose ePHI.

Project objectives

• Reduce lateral-movement opportunities through documented security zones and least-privilege interzone access.

• Improve endpoint detection and investigation readiness using EDR telemetry and centralized log correlation.

• Support HIPAA Security Rule risk-management, access-control, and audit-control objectives.

• Create a phased adoption plan, ownership model, security procedures, and measurable acceptance criteria.

Scope and method

Analyzed the scenario, stakeholders, regulatory drivers, and root causes; developed a target-state network and monitoring architecture; specified security policies and operational procedures; and defined conceptual tabletop scenarios and KPIs for future validation.

Evidence boundary: This case study reflects the proposal and final written capstone. It does not claim real-world control installation, successful penetration testing, measured risk reduction, or formal HIPAA certification.

1 Architecture and security controls

Target-state segmentation

Zone	Proposed protection / traffic policy
Clinical and administrative workstations	Separate user zones; only approved application connections to protected resources
EHR and ePHI servers	Protected server segment; restrict access to documented business and clinical flows
Medical devices	Dedicated segment with narrowly scoped communications
Management systems	Dedicated administration segment with least-privilege access
Segmentation gateway	Next-generation firewall enforcing interzone policies and logging allowed/denied connections

Detection, response, and identity controls

• **EDR:** Behavioral detection on managed Windows endpoints; collect process, network, and authentication telemetry; monitor agent coverage and health.

• **SIEM:** Centralize firewall, endpoint, server, and application logs for suspicious-access and lateral-movement detection use cases.

• **Incident response:** Correlate EDR and firewall events, investigate affected accounts and endpoints, and follow containment and escalation procedures.

• **Identity:** Least-privilege administration and access restrictions; Active Directory and group-policy concepts appear in the design.

Illustrative incident-response sequence

1. Detect	2. Investigate	3. Contain	4. Improve
EDR or firewall alert	Review process, sign-in and network telemetry	Isolate endpoint; revoke/reset access; adjust rules as warranted	Review incident, tune controls and update procedures

This workflow represents the documented proposed operating model, not a recorded production incident.

2 Governance, risk and compliance

Policy and procedure deliverables

• Internal network segmentation policy: defined zones, approved traffic flows, deny-by-default approach, and documented exceptions.

• Endpoint security standard: EDR deployment scope, configuration baseline, telemetry expectations, coverage monitoring, and tuning.

• Logging and incident-response procedure: log sources, monitoring expectations, escalation responsibilities, and investigation steps.

Standards and regulatory alignment

Reference	Application in the academic design
NIST SP 800-207 / Zero Trust	Explicit verification, segmentation, reduced implicit trust, least privilege
NIST SP 800-53	Control-oriented documentation for access restrictions, monitoring, and governance
HIPAA Security Rule	Risk analysis and safeguards relating to access control, audit controls, and protection of ePHI

Alignment is an analytical mapping, not an audit finding or determination that the modeled organization complies with HIPAA.

Stakeholder and implementation planning

The proposal identifies responsibilities for security leadership, network engineers, endpoint teams, clinical application owners, compliance/privacy officers, IT operations, and third-party vendors. It defines a **16-week conceptual plan**: baseline assessment (weeks 1–4), target design (5–8), pilot and rollout planning (9–12), and evaluation/documentation (13–16).

Principal implementation risks

• Overly restrictive firewall rules disrupting clinical applications; mitigate with application-flow mapping and pilots.

• EDR and SIEM alert fatigue; mitigate with tuning, ownership, and response procedures.

• Vendor access and legacy systems retaining excessive privileges; mitigate through exception tracking and staged remediation.

3 Evaluation framework and professional relevance

Proposed evaluation scenarios

• **Compromised workstation:** Attempt unauthorized connections from a clinical workstation to protected ePHI servers; verify that intended interzone restrictions block the path.

• **Vendor account misuse:** Assess whether a third-party identity can reach resources outside its approved access scope.

• **Ransomware-like activity:** Evaluate whether endpoint behavioral detections produce useful alerts and trigger the documented escalation path.

Planned measures of success

Metric	Intended assessment
Critical-system segmentation	Share of identified ePHI systems assigned to protected server zones
Attack-path reduction	Change in reachable internal services from a standard workstation
EDR coverage and health	Deployment and update coverage of in-scope managed endpoints
Response effectiveness	Timeliness and quality of high-severity incident triage and escalation

Results status: The final paper explicitly characterizes its evaluation as conceptual and describes planned tests. It does not provide independently verified before-and-after performance measurements.

What this work demonstrates

For GRC and technology risk: Scoping a risk problem, documenting safeguards, mapping controls to frameworks, defining stakeholders, planning remediation, and designing audit-relevant evidence and metrics.

For SOC, endpoint, and network security: Understanding lateral movement, segmentation policy, EDR telemetry, SIEM correlation, and structured incident response.

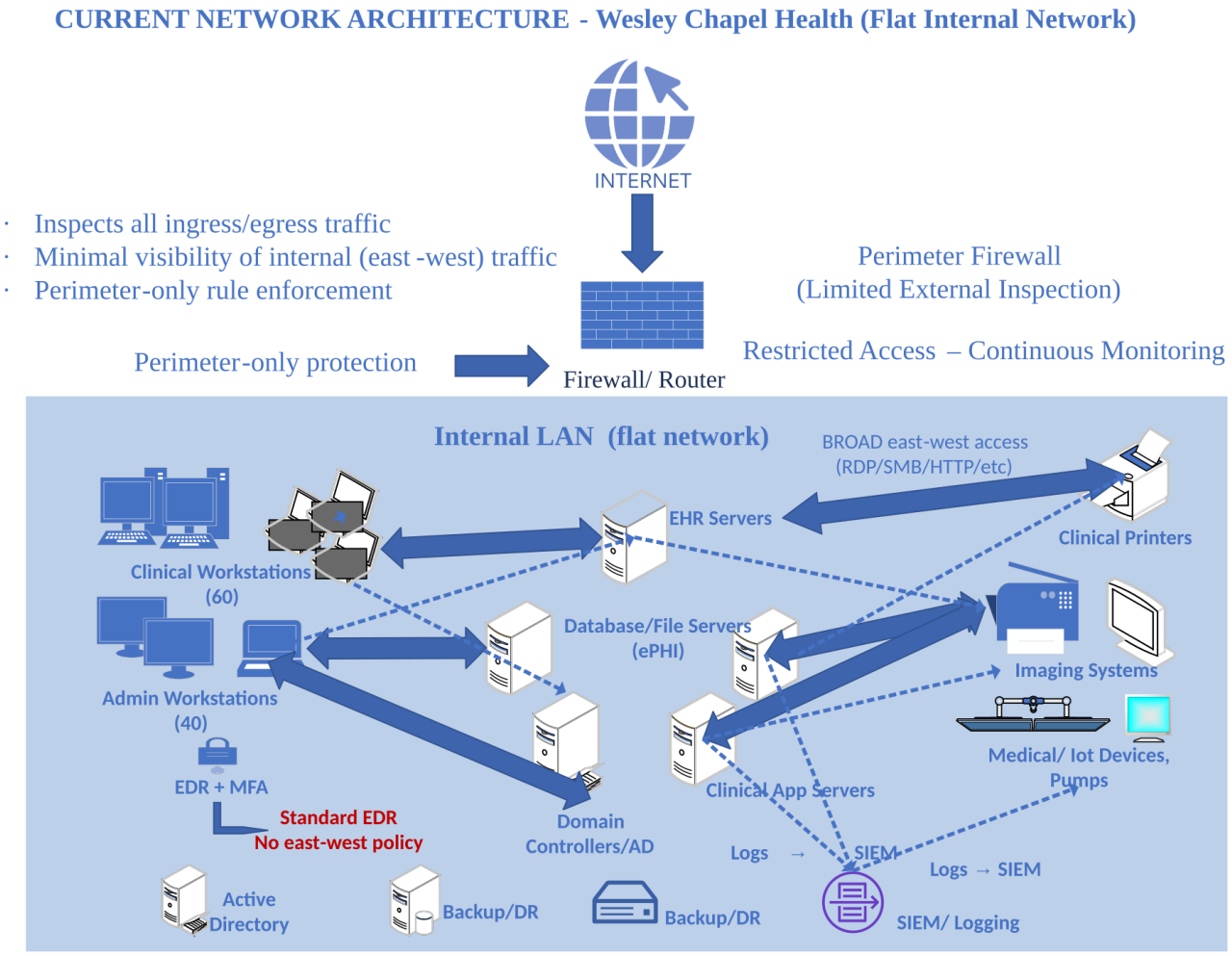
Source and publication notes

Adapted from two original WGU academic submissions: *Cybersecurity Graduate Capstone Project Proposal* and *Cybersecurity Graduate Capstone Project Task 3*, both titled *Zero Trust Network Segmentation with EDR*. The case-study organization is presented as a modeled academic scenario. Student identification information has been omitted. This summary does not reproduce the full academic submissions.

Selected frameworks named in the source work: NIST SP 800-207, NIST SP 800-53, and the HIPAA Security Rule. For formal citations, refer to the bibliography in the original submissions.

Figure 1. Current-state network architecture

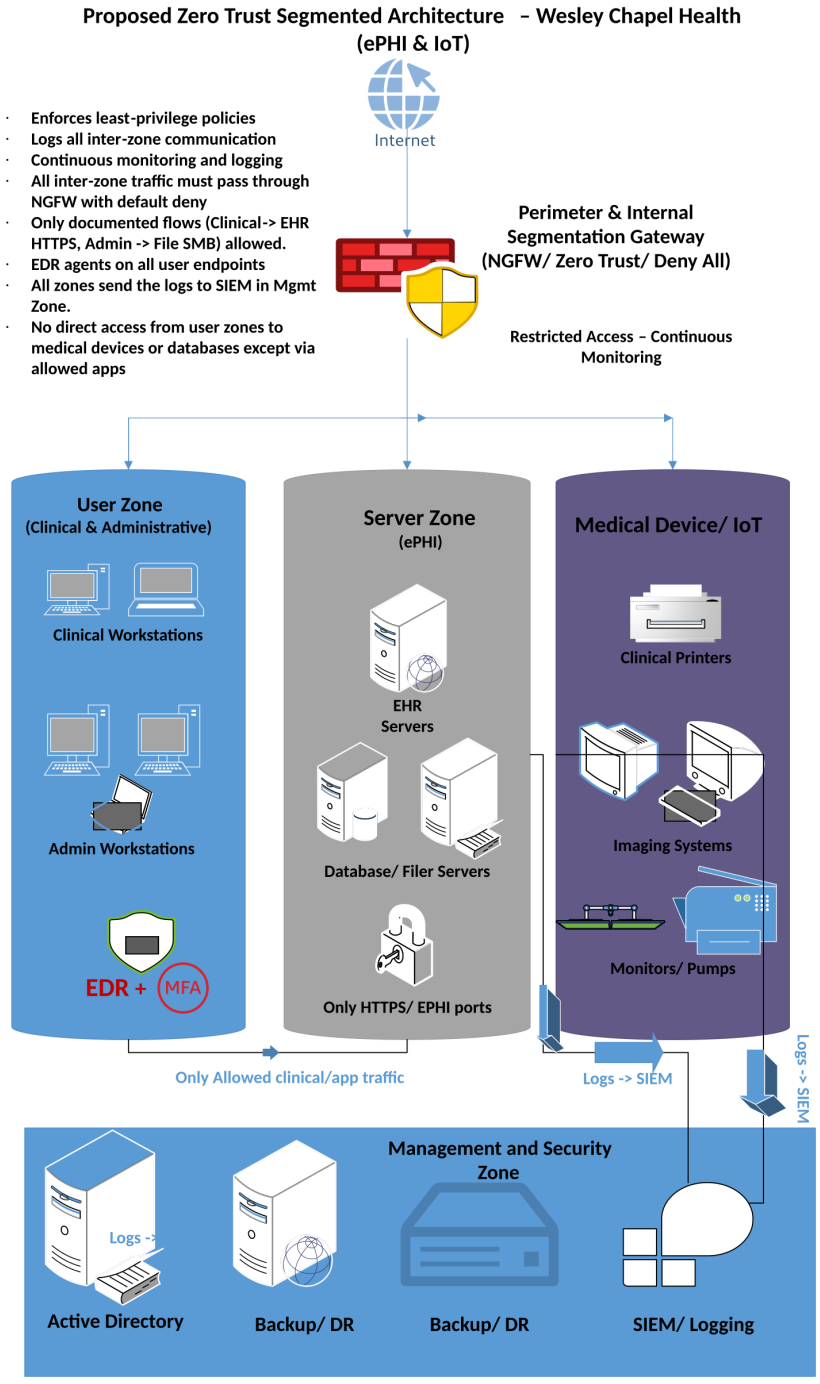
Original capstone diagram showing a largely flat network with broad east-west communication and perimeter-focused controls.



Academic conceptual architecture; not a verified production deployment.

Figure 2. Proposed Zero Trust architecture

Original capstone diagram showing distinct user, protected server, medical device and management/security zones.



Academic conceptual architecture; not a verified production deployment.